

Selection of the MERIDIAN group security framework

A single backbone for four subsidiaries — recommendation and decision requested

ISSUER	Group CISO, MERIDIAN — instructing team Group 4 (Translog)
RECIPIENT	Executive Committee
SCOPE	MERIDIAN Santé · Logistique · Éducation · Territoires — instructed scope MERIDIAN-LOGISTIQUE, instance translog-b
DECISION	Adopt ISO/IEC 27001:2022 as the group framework · launch the initial assessment · mandate the Group CISO on deployment scope
ANSWER BY	Thursday's committee session

Executive summary

MERIDIAN has four subsidiaries with four different obligation profiles and, to date, no common security framework. Three of the four will enter the scope of the European NIS 2 directive upon promulgation of the French transposition law; the fourth will not, and it is the one carrying 45,000 user accounts. Obligations already in force — GDPR across all four, HDS for Santé's hosting providers, RGS in the environment of Territoires' clients — depend on no legislative calendar at all, and two client relationships are already asking for security evidence in writing.

We examined three candidates against a weighted grid: the ANSSI hygiene guide, the forthcoming French control framework (ReCyF), and ISO/IEC 27001:2022. **We recommend ISO/IEC 27001:2022 as the group's backbone framework, across all four subsidiaries.** It is the only candidate covering the whole perimeter — regulated and unregulated subsidiaries, information systems and industrial environments — and the only one producing evidence a third party can act on. The framework is already imported into the group's governance tool and an initial assessment is created and attached to the MERIDIAN scope: a favourable opinion requires no technical prerequisite.

On cost, the position is explicit rather than deferred. ISO is the only one of the three whose text must be purchased and the only one carrying a third-party audit — and the only one that buys the deliverable two clients have already demanded in writing. The Direction Générale's requirement of *no new budget in the first year* is met by sequencing rather than by promise: the certification audit cannot be contracted before the deployment scope is settled, which is exactly what this decision mandates. §II.3 sets out what each option costs; §III.2 states what we commit, what we defer and against what trigger, and what we cannot price today — with the missing input named and its owner identified.

This choice delivers no regulatory compliance by itself, and we say so before an auditor does. What it delivers is a single language in which the group can finally measure itself.

230 / 300 Weighted score of ISO/IEC 27001:2022, ahead of ReCyF at 205 and the hygiene guide at 135
3 of 4 Subsidiaries entering NIS 2 scope; the fourth remains fully exposed and fully unregulated
123 Evaluable requirements already imported, of which 93 Annex A controls, assessment blank

How to read this note

The note is built in three themes, each answering one question the Committee actually asks, in the order in which it asks it. It is not a report that surveys a subject; it is a document that requests one decision, and it is written so that “no” is a possible answer.

THE THREE THEMES AND WHAT EACH ANSWERS

THEME	THE QUESTION IT ANSWERS	SECTIONS
I	<i>“What has changed that makes a framework a committee matter this quarter?”</i>	I.1 Four obligation profiles · I.2 NIS 2 scope, subsidiary by subsidiary · I.3 Obligations already in force · I.4 Commercial pressure · I.5 The internal trigger · I.6 What we do not claim
II	<i>“What was on the table, and why this one rather than the others?”</i>	II.1 The three candidates · II.2 The selection grid · II.3 What each option costs · II.4 A condition, not a score · II.5 Sensitivity · II.6 Recommendation · II.7 What the mappings transfer · II.8 The best objection
III	<i>“What does this cost me, what does it leave open, and what am I signing today?”</i>	III.1 The decision is already tooled · III.2 The cost position · III.3 Limits and blind spots · III.4 What we monitor · III.5 The day after a yes · III.6 Decision requested

Traceability of every claim

Nothing here is invented for the occasion. Every claim carries a marker naming the piece of the instructed file it is drawn from, so a reader can check the source rather than take the sentence on trust. The markers are the first thing a reviewer tests.

- (applicability) NIS 2 applicability analysis, subsidiary by subsidiary — sector and size filters, the four characterisations, the sanction regimes
- (grid) Weighted selection grid, veto rule and sensitivity tests — criteria, weights, the fifteen scores, the two flip tests
- (mappings) Requirement mapping tables and their verdicts — what is reusable between frameworks, and what is not
- (import) Framework identity sheet and the import into instance **translog-b** — edition, counts, the initial assessment
- (dossier S1) Session 1 — gap analysis, target governance, three-year roadmap and its budget axes
- (dossier S2) Session 2 — inventory, business and supporting assets, the group mapping

One caution on what a business case is

It asks for **one** steering decision. It is not the scoping note, which organises work already decided, and not a project plan, which will break down the implementation after the decision. Section III.6 carries the single question the Committee is asked to answer.

Why this decision, and why now

“What has changed that makes a framework a committee matter this quarter?”

I.1

Four subsidiaries, four obligation profiles, one absent framework

MERIDIAN is a 150-person holding and four subsidiaries totalling 7,550 employees. Their businesses do not overlap, and neither do their obligations.

SUBSIDIARY	STAFF	ACTIVITY	OBLIGATION PROFILE IN ONE LINE
Santé	3,200	4 care establishments	Care mission, health data, HDS requirement on its hosting providers
Logistique	2,800	6 warehouses; transport, temperature-controlled storage, third-party dispatch	Industrial perimeter, contractual commitments to a pharmaceutical client
Éducation	900	Teaching portal, 45,000 user accounts	Personal data of minors; shared IT department with Territoires
Territoires	650	Citizen services platform for ~30 client local authorities	Clients are public bodies; RGS applies to their environment

Until this week the group had no common framework, no consolidated compliance measurement, and no shared vocabulary in which one subsidiary's posture could be compared with another's. Each subsidiary managed its security as it saw fit – the structural gap our own analysis identified as the root of every other gap (dossier S1).

I.2

Three of four subsidiaries enter NIS 2 scope — and the fourth does not stop existing

NIS 2 applies through two cumulative filters: the sector (Annex I “highly critical”, Annex II “other critical”), then size. At MERIDIAN the size filter discriminates nothing — all four subsidiaries sit far above every threshold. The entire characterisation therefore turns on the sector, which is to say on an exact description of the activity actually performed. That is mapping work, not legal work (applicability).

SUBSIDIARY	ANNEX	PROVISIONAL CHARACTERISATION	WHY IT IS NOT CLOSED
Santé	I — health	Essential entity	No serious alternative reading
Logistique	I or II	Essential or important, on qualification	Annex I “road transport” names road authorities and intelligent-transport operators, not every private freight carrier; Annex II “postal and courier services” fits the dispatch activity. The annex, not the size, decides the category
Territoires	I, two hypotheses	Depends on a choice France has not made	Either local authorities are brought under “public administration”, or the platform qualifies as a managed ICT service (B2B) — which would make it essential regardless of that choice
Éducation	Neither	Out of scope	Annex II names research, not teaching. The sector filter fails at step one, so the size filter is never reached

Two consequences worth stating in committee

The category has a price. An essential entity is supervised both ex ante and ex post, with fines capped at 2% of worldwide turnover; an important entity is supervised ex post only, capped at 1.4%. The qualification arbitration on Logistique is therefore a financial question, not a taxonomic one (applicability).

Out of scope is not out of risk. Éducation carries 45,000 accounts (applicability) and eleven ungoverned online services surfaced by its own inventory work, one of them a generative-AI tool receiving pupils' marked work (dossier S2). No NIS 2 obligation targets it. Nothing about that removes the exposure.

We therefore prepare Logistique on the **high hypothesis** – essential entity – while carrying the qualification question to arbitration. Preparing for the more demanding regime and then being classified “important” costs a few months of advance; the reverse costs a compliance plan redone under calendar pressure.

I.3

The obligations already in force depend on no calendar

It would be a mistake to present this decision as a bet on a law. Three obligation sets already bind the group today, and none of them waits for a transposition (applicability) :

- **GDPR** applies to all four subsidiaries, without exception and without threshold.
- **HDS** (health-data hosting) applies to Santé's hosting providers, and is therefore a requirement the subsidiary must impose contractually and verify.
- **RGS** governs the environment of Territoires' public-sector clients, and reaches the subsidiary through those clients.

A framework decision that only made sense if a particular law were promulgated on a particular date would be a fragile decision. This one does not depend on that.

I.4

The commercial pressure is already at the door

Two demands are already formulated, in writing, by paying clients (grid) :

- The ~30 client local authorities of Territoires ask for security guarantees as a condition of the relationship.
- The pharmaceutical client of Logistique has announced a security questionnaire for its next audit – on a contract already carrying €12,000/day stoppage penalties and annual cold-chain audits (dossier S2).

This is the point on which we ask the Committee to be explicit, because our recommendation rests on it: at MERIDIAN, **evidence a third party can act on is not a communications luxury, it is a commercial condition.** A self-declaration answers neither of those two demands.

I.5

The internal trigger: we can now decide on an instructed file

Since this week the group holds a mapping maintained in a common governance tool and a framework imported and ready to be assessed (import). The material for a reasoned choice – the weighted grid, the mapping verdicts, the identity sheet, the import proof – exists and is attached to this file. **Deciding now, on an instructed file, costs less than deciding under the constraint of a regulatory calendar, whatever that calendar turns out to be.**

I.6

What this theme does not claim

Applicability **triggers obligations; it measures nothing.** An entity can be in scope and well protected, or out of scope and vulnerable. Nothing above says MERIDIAN is compliant, nor that it will be at promulgation – on Logistique specifically, with no incident procedure, no IT/OT segmentation and no nominative accounts on the provider side, we are far from it.

II

What we compared, and what we recommend

“What was on the table, and why this one rather than the others?”

II.1

The three candidates

Three frameworks were on the Committee's table. Each is summarised here by its **real strength first**, because a note that caricatures the alternatives convinces only its author.

OPTION	REAL STRENGTH	LIMIT
ANSSI hygiene guide	Free, 42 measures, two levels, its own tracking tool: usable tomorrow morning , and the fastest way to bring a concrete risk down	No legal force, no evidence beyond a self-declaration, weak on group governance (grid)
ReCyF forthcoming ANSSI control framework	Best placed on the binding-nature criterion : its security objectives are intended to be set by decree; it is before ReCyF that NIS 2 compliance will be demonstrated (grid)	Working version circulated since March 2026, no certification possible, and silent on a subsidiary outside NIS 2 scope (mappings)
ISO/IEC 27001:2022	Covers all four subsidiaries, information systems and industrial alike, and alone leads to third-party certification (grid)	Voluntary: binding only through contract; the clause 4–10 management system and the certification audit are a real, and at this stage unpriced, effort

II.2

The selection grid

Five criteria, weighted against the MERIDIAN context, scored 0–3, with a written justification behind every score. The mechanics matter less than the discipline: **a weighted grid does not compute the right answer, it makes the deliberation transparent and contestable**.

WEIGHTED SELECTION GRID – GROUP SECURITY FRAMEWORK (GRID)

CRITERION	WEIGHT	ISO/IEC 27001:2022	RECYF	HYGIENE GUIDE
Binding nature, current or forthcoming	30	1 – voluntary; binding only by contract, which is already happening	3 – objectives intended to be set by decree	1 – no legal force; state-of-the-art argument only
Coverage of the group perimeter	25	3 – 93 controls in four themes, plus management clauses: IS, OT and steering	2 – 20 objectives built for NIS 2 entities; silent on Éducation; objectives 16–20 target essential entities only	1 – 42 generalist measures, weak on group governance and industrial systems
Evidence enforceable towards third parties	20	3 – the only one of the three leading to third-party certification, on a written scope	1 – no certification; usable before the authority, not before a client local authority	1 – its tracking tool yields a self-declaration only
Maturity and stability of the text	15	3 – 2022 edition, maintained international standard, ~1,000 certified organisations in France end-2023	1 – working version; objectives not yet set by decree	2 – stable, but the 2017 v2: stable by immobility as much as by maturity
Tooling and implementation effort	10	2 – imports natively into the group tool, but the management system and audit are a real charge	3 – free, 20 objectives, and a native library in the instance (verified on screen): the lightest implementation charge of the three	3 – free, two levels, its own tracking tool
Weighted total (out of 300)	100	230	205	135

Detail – ISO: 30+75+60+45+20 · ReCyF: 90+50+20+15+30 · Hygiene: 30+25+20+30+30.

ISO leads ReCyF by 25 points out of 300 and the hygiene guide by nearly 100. **The hygiene guide wins the effort column and loses every other: it is a starting point, not a group backbone.**

II.3

What each option costs

The grid scores tooling and implementation effort at weight 10 — deliberately low, because the charge cannot be allowed to choose the backbone of a 7,550-employee group, but deliberately not zero, because the Direction Générale requires **no new budget in the first year** (grid) . That single cell compresses several different kinds of money. Before arbitrating, the Committee should see them separated, because the three options do not carry cost in the same places.

The rule applied below is the group's own: every figure carries its base, and where the file gives no figure we say what the number will be computed from rather than inventing one. A bare number is not an arbitration; it is an opinion in costume (dossier S1) .

RESPECTIVE COSTS OF THE THREE CANDIDATES

COST COMPONENT	ANSSI HYGIENE GUIDE	RECYF	ISO/IEC 27001:2022
Acquiring the text	None — published free by ANSSI (grid)	None — published free by ANSSI (grid)	The only one of the three that must be purchased. ISO/IEC standards are sold by ISO and its national members; the two ANSSI documents are not
Internal implementation effort	Lowest — 42 measures, two levels (standard / reinforced), no management system to run (grid)	Medium, and indeterminate for us — 20 objectives, but objectives 16–20 apply only to essential entities: Logistique's effort depends on a qualification arbitration not yet made (applicability)	Highest — the 93 Annex A controls <i>plus</i> the clause 4–10 management system, which is a recurring operating cost, not a one-off project (grid)
Tooling	Its own tracking tool, free — but standalone, outside the group instance (grid)	Native library, already in the instance — provider ANSSI, v2.5 of 17/03/2026, published 09/07/2026 (import) . Nothing to build; the charge is the 20 objectives themselves, the lightest of the three	Zero marginal cost — imports natively, and the import is already done: 123 requirements created (import)
Third-party audit	Not possible — the tracking tool yields a self-declaration only (grid)	Not possible — no certification exists (grid)	Certification audit, surveillance audits, three-yearly re-certification. Not priced at this stage — §III.2 gives the drivers it will be priced against
Recurring cost	Near zero	Active watch only	Management-system upkeep plus the audit cycle
Committed in year one	None	None	None — by sequencing; see overleaf

Why “free” is not the same as “cheap”

Two of the three options cost nothing to obtain, and that is the entirety of their cost advantage. The hygiene guide's zero buys a self-declaration. ReCyF's zero buys a working document that cannot be certified and that says nothing about one subsidiary in four (grid) (mappings). ISO is the only option that costs money, and it is the only one that buys the deliverable the ~30 client local authorities and the pharmaceutical client's announced security questionnaire are actually asking for (grid).

The arbitration the Committee is being asked to make is therefore not *cheapest versus most expensive*. It is: **what does the spend buy that the saving does not?** Put in the terms of the sensitivity test in §II.5, if third-party evidence is judged accessory, the saving wins and the ranking flips — and that judgement belongs to the Committee, explicitly.

Why year one commits nothing new — a consequence, not a promise

The decision requested has three parts: adopt the framework, open the initial assessment, mandate the Group CISO on scope. Each carries zero new external spend, for a structural reason:

- **The assessment is already created** and attached to the MERIDIAN-LOGISTIQUE scope, blank. Opening it costs nothing (import).
- **Collecting evidence against the 123 requirements is internal effort** by subsidiary CISO and DSI teams that already exist, charged against the *trust foundation* axis that already holds 40% of the multi-year security budget (dossier S1).
- **The certification audit is the only genuinely new external spend, and it cannot be contracted before the scope is settled** — which is precisely what the mandate covers. The zero is produced by the sequencing, not asserted against it.

One consequence must be stated so it is not double-counted later: **remediation cost is not certification cost**. The IT/OT segmentation that any industrial ISO scope presupposes is already funded at the 24-month milestone under the *OT/IT resilience* axis, which holds 35% of the same envelope, alongside the 15% reallocation from existing envelopes pegged to the obsolescence KRI (dossier S1). The framework decision **opens no fourth budget axis** and must not be charged with work already financed.

II.4

One criterion is a condition, not a score

A weighted average compensates — that is its function — and some criteria do not compensate. We therefore placed **coverage of the perimeter above the calculation**, as a veto rule written before any score was given:

Any framework that cannot simultaneously cover Santé's sectoral obligations (HDS), Logistique's industrial perimeter (PLCs, WMS, cold chain) and a subsidiary outside NIS 2 scope (Éducation) is set aside, whatever its weighted score.

Applied to the three candidates, this changes one thing and changes it before the arithmetic: **ReCyF cannot be the group's backbone**, because it has nothing to say about an entity that is not a NIS 2 entity. It is not its score of 205 that sets it aside; it is a condition it does not meet. The distinction matters for the Committee — we do not discard ReCyF as *poor*, we discard it as *backbone*, and we retain it as an actively monitored framework (§III.4).

II.5

Sensitivity: where the ranking flips

An analysis that does not test its own reversal is a staging, not an analysis. ReCyF leads ISO on exactly one criterion, so two tests suffice (grid) :

TEST	MANIPULATION	RESULT	READING
Weight transfer	Binding nature 30 → 39; maturity 15 → 6	ISO 212, ReCyF 223 – flip	Requires moving 9 points out of 100 – nearly a third of the weight of the already-heaviest criterion – <i>and</i> reducing text stability to almost nothing. That is not a fine adjustment, it is a change of doctrine
Criterion removal	Drop “evidence enforceable towards third parties” (20)	ISO 170, ReCyF 185 – flip	This test names what actually protects the recommendation: the client local authorities and the pharmaceutical questionnaire. If the Committee judges enforceable evidence accessory, it should choose differently – and say so explicitly

What this sensitivity teaches is that the arithmetic is not what carries the recommendation – the veto rule is. Both tests flip, and by wider margins than the base gap of 25 points suggests. If the choice rested on the weighted total alone it would be fragile. It rests instead on a condition – covering a subsidiary outside NIS 2 scope – that ReCyF fails whatever its score. The recommendation is therefore robust without being unassailable, and it rests on two contextual judgements the Committee must validate openly: that evidence towards third parties counts, and that the stability of the text counts.

II.6

Recommendation

We recommend adopting ISO/IEC 27001:2022 as the backbone of MERIDIAN group security, across all four subsidiaries. Three arguments designate it, and a fourth makes it immediate:

1. It is the only option covering the entire group perimeter (grid) . Coverage was treated as a condition, not a score (§II.4). ReCyF fails that condition – not through weakness, but through purpose.
2. It is the only option producing evidence a third party can act on (grid) , on a scope written down in black and white. Neither the client local authorities nor the pharmaceutical questionnaire is satisfied by a self-declaration.
3. Part of the effort will be reused, not redone (mappings) – with the boundary of that reuse stated inside the argument rather than a page later; see §II.7.
4. The decision is already tooled (import) . The framework is imported into the group instance and the initial assessment is created and attached to the MERIDIAN scope, blank. A favourable opinion requires no technical prerequisite.

II.7

What the mappings actually transfer

A mapping table sets a source framework's requirements against a target's, line by line, to reuse what is done and see what remains. We examined three requirements in detail. **All three verdicts are intersect; none is equivalence** — as in the whole 180-line reference set shipped with the governance tool, where no single line declares two requirements equivalent (mappings) .

SOURCE REQUIREMENT	ISO/IEC 27001:2022 TARGET	RELATION	WHAT THE SOURCE DEMANDS THAT THE TARGET DOES NOT
NIS 2 1.1-EI/EE — list activities, services, owners, supporting systems	Clause 4 (context) + A.5.9	intersect	Listing activities outside the applicability criteria. In one sentence: ISO lets you choose your scope; NIS 2 forbids you to choose it
ReCyF objective 2 — digital security governance framework	Clauses 5, 6, 9 + A.5.1, A.5.2	intersect (strong)	Nothing material — but the reuse is bounded: one objective out of twenty, on the certified scope only
Hygiene guide, measure 4 — sensitive assets and network diagram	A.5.9, A.5.12	intersect	The guide's “simplified diagram” is <i>less</i> demanding than the NIS 2 inventory: complying with the guide does not finish the NIS 2 requirement

The doctrine that follows is one line, and we state it before the Committee infers a stronger one: **there is no general presumption of compliance**. ReCyF accepts a certified ISO management system as an acceptable means of demonstrating **its governance objective alone — one objective out of twenty — and only on the scope covered by the certificate**. Beyond that, a maintained mapping table transfers nothing; it lets us attribute each piece of ISO evidence to the obligation it serves, and above all shows what remains to be produced.

II.8

The best objection to our recommendation, and our answer

The serious objection is not cost. It is that **the authority will inspect us against ReCyF, not against ISO**, and that a badly chosen backbone makes the work happen twice. It deserves to be put in the note rather than left for the room.

We accept the objection and answer it in three parts. ReCyF is a working document that cannot today be made the backbone of a 7,550-employee group. It says nothing about one subsidiary in four. And the distance between the two frameworks is handled by mapping, not by a second programme (mappings) . We therefore hold ReCyF under **active monitoring**, ready to become the NIS 2 demonstration framework once its objectives are fixed by decree — at which point the backbone will not have to change.

Two further objections we have already answered in writing, so that the room does not have to improvise them. *That the note should compare more options*: three candidates were on the table; adding uninstructed options would lengthen the note without changing the decision. *That the cost of certification is missing*: pricing a certification before the scopes are settled produces a false number — the present decision commits no new budget in year one, and a separate note will carry the costing.

III

What the decision commits, what it does not cover, and what is asked

“What does this cost me, what does it leave open, and what am I signing today?”

III.1

The decision is already toolled

Before recommending a framework we verified its identity — not its merit, its identity. The failure this avoids is banal and expensive: working six months against an old edition, an unofficial translation, or a truncated document found on a third-party site.

FRAMEWORK IDENTITY SHEET (IMPORT)

FIELD	VALUE
Exact name and publisher	ISO/IEC 27001:2022, published jointly by ISO and IEC
Edition and date	3rd edition, 25 October 2022
Amendment in force	Amd 1:2024
Official French title	Systèmes de management de la sécurité de l'information — Exigences
Status for MERIDIAN	Voluntary, and it will remain voluntary after promulgation. What changes then is that certification may count as an acceptable means of compliance for the French framework's governance objective, on the certified scope only — that changes its value, not its status

The import is then a matter of fact, not of intention. In instance translog-b, attached to scope MERIDIAN-LOGISTIQUE (import) :

123
Evaluable requirements created — clauses 4 to 10 plus the Annex A controls
93
Annex A controls, distributed 37 organisational / 8 people / 14 physical / 34 technological
0
Requirements assessed. The assessment is blank — which is its normal state today

Reconciliation, so the figures can be checked rather than believed: 123 evaluable requirements = the clauses 4 to 10 of the standard body + the 93 Annex A controls; and 93 = 37 + 8 + 14 + 34. Any other total means either an incomplete import or a different library — both corrected in two minutes now, or in two days on the day of the audit.

Two provenance notes, because these objects are what the group will be measured on rather than this prose. First, the instance dates and attributes every object it holds: that is what makes an export evidence rather than an assertion. Second, **what is in the library is a matter of fact, not of assumption**. ReCyF is present — provider ANSSI, v2.5 of 17/03/2026, published 09/07/2026 — and we found it and chose not to import it: one imports the backbone, not everything available, or the instance stops meaning anything. An earlier draft asserted the opposite, and our own screenshot corrected it (import) .

Three requirement–evidence pairs are already identifiable from work the group has done: clause 4 (context) against the session-2 mapping of business and supporting assets; clause 5.3 (roles and authorities) against the RACI matrix and the scoping note of session 1; A.5.9 (inventory of information and associated assets) against the prioritised inventory and the assets entered in the instance (dossier S1) (dossier S2) . They will be the first three exhibits of the audit. *The group's consolidated top-five critical assets, arrived at in plenary, is cited by reference only: it is not part of our own written file, which instructed Logistique, and the five lines will be checked against the plenary record before final submission.*

One sentence to keep the tooling honest: importing is not complying. The instance now holds the list of requirements, not their satisfaction. Our compliance percentage has not moved by a point because the standard entered the tool. The import installs the yardstick; measurement starts afterwards.

III.2

The cost position: what is committed, what is deferred, and against what

§II.3 set out what each option costs. This section states what the group actually commits by saying yes, and – the harder half – what it deliberately does not price today and why that is a discipline rather than an omission.

What is committed now

Nothing new. The three parts of the decision – adopt, open the assessment, mandate the scope – consume existing internal effort against budget axes already apportioned: the *trust foundation* axis at 40% of the multi-year security budget carries the evidence collection, and the *OT/IT resilience* axis at 35% already carries the segmentation work at its 24-month milestone (dossier S1). The Direction Générale's requirement is met without an exception being asked for.

What is deferred, and against what trigger

The certification costing is deferred, and its trigger is named: **it is produced once the deployment scope has been settled subsidiary by subsidiary**, which is the mandate this decision confers. Pricing it before that produces a false number, because a certification quotation is driven by variables the mandate exists to fix.

COST DRIVER	WHY IT CANNOT BE FIXED TODAY	WHO SETTLES IT
Number of certificates – one group scope or one per subsidiary	This is the object of the mandate itself	ComEx decision, on Group CISO proposal
Number of sites in scope	E1–E6 for Logistique, 4 care establishments for Santé; audit day-count scales with sites	Group CISO with subsidiary CISOs
Headcount in scope	Between 650 and 7,550 depending on the answer above	Follows from the scope decision
Whether the industrial perimeter is included	Not honestly declarable before the Logistique network diagram exists and IT/OT is segmented – the 24-month milestone (dossier S1)	Trajectory, not this decision
Remediation already financed	Must not be re-charged to the certification: it sits in an approved axis	Group CISO, at costing

What we cannot price at all today, and who owns the missing input

The regulatory exposure is the one figure we are unable to complete, and we prefer to name the gap than to fill it with an estimate. Fines are capped as a percentage of **worldwide turnover** – 2% for an essential entity, 1.4% for an important one – and **the subsidiaries' turnover and balance-sheet figures have never been communicated to the Group CISO** (applicability). The assessment is made entity by entity, not at consolidated group level, so it is Logistique's 2,800-employee entity that would be measured, not the group's 7,550.

Two things follow, and both are actionable rather than rhetorical. **The floor is knowable even though the percentage is not:** the caps carry floors of roughly €10M for an essential entity and €7M for an important one, so an order of magnitude exists today without any figure from the holding. And **the missing input has a named owner:** the turnover and balance-sheet data must be requested from the **holding's Chief Financial Officer**, and will in any case be required in the registration file submitted to the national authority (applicability). We record that request here as an action arising from this note.

What it costs not to decide, or to decide wrongly

- **Not deciding** – the pharmaceutical client's announced security questionnaire arrives against a contract already carrying €12,000/day stoppage penalties and annual cold-chain audits, and ~30 client local authorities condition their relationship on guarantees (grid) (dossier S2). The cost of having no answer is commercial and immediate, and it does not wait for a law.
- **Deciding wrongly** – adopting a working document as backbone means redoing the work when it changes, on a framework that in any case says nothing about one subsidiary in four (mappings).
- **The exposure the framework does not remove** – a WMS stoppage beyond six hours blocks 40% of the group's shipped volume, and backups have never once been restored since commissioning (dossier S2). No framework choice fixes that. It is named here so the Committee does not read a framework decision as a resilience decision.

III.3

Limits and blind spots

A note with no declared limits is precisely what makes senior management suspicious. Six follow, of which two are our own rather than the regulator's.

1. **This choice delivers no regulatory compliance.** There is no general presumption of NIS 2 compliance through ISO; the only recognised transfer covers one objective out of twenty, on the certified scope only (mappings) . GDPR, HDS and RGS continue to apply independently (applicability) .
2. **Owned blind spot, and a serious one: ISO lets the organisation choose its management-system scope, where NIS 2 forbids choosing it.** A certificate obtained on the best-run subsidiary would have proved nothing about the other three. That is exactly why the decision requested covers all four subsidiaries and an explicitly settled, subsidiary-by-subsidary scope.
3. **Second owned blind spot, technical: there is to this day no network diagram of Logistique**, and its IT and OT networks are interconnected without segmentation – with an integrator connected through a 4G box outside the supervised network and ~300 Wi-Fi handheld scanners. **No ISO scope including the industrial perimeter could be honestly declared before that work is done**, already booked at 24 months in our roadmap (dossier S1) .
4. **The French text will evolve** until its decrees and orders. Its working version is under active monitoring and the mapping table will be revised at each publication.
5. **The cost of certification is not priced** at this stage – deliberately, and against a named trigger: the costing follows the scope mandate, and its drivers, its missing input and the owner of that input are set out in §III.2. The present decision commits no new budget in year one.
6. **The recommendation is robust, not unassailable:** the grid flips if the Committee judges third-party evidence accessory (grid) . That is a contextual judgement belonging to the Committee, and it must be made explicitly.

III.4

What we monitor, and how the remainder is treated

The framework choice leaves a remainder. We treat it by named means, none of which is a second programme.

REMAINDER	TREATMENT	OWNER
Future NIS 2 demonstration	Active monitoring of ReCyF and the transposition law; ReCyF becomes the demonstration framework once its objectives are set by decree	Group CISO
Reuse of ISO effort towards NIS 2	Mapping table maintained , revised at each publication, so each piece of ISO evidence is attributed to the obligation it serves	Group CISO
Concrete risks that will not wait for a management system	Immediate application of the hygiene guide where urgency demands it – starting with Logistique's IT/OT segmentation	Subsidiary CISOs
Sectoral obligations (GDPR, HDS, RGS)	Unchanged, applied independently of this decision	Subsidiary CISOs / DPO

III.5

What happens the day after a yes

The framework decision is not a standalone event; it is the third stone of a trajectory already approved in principle (dossier S1) . It slots in without moving anything.

- IMMEDIATELY The initial assessment is opened, and the four subsidiary CISOs are notified of the evidence-collection schedule. No new budget. In the same movement, the turnover and balance-sheet data are requested from the **holding's Chief Financial Officer**: they are the missing input of §III.2 and will in any case be required in the registration file for the national authority (applicability) .
- NEXT AUDIT The imported framework becomes the **audit framework**: the group measures, requirement by requirement, the gap between what it claims and what it does. This business case, once accepted, is the first exhibit in that file – it states which yardstick we accept to be measured against, and on which scope.
- 12 MONTHS Priority-1 gaps addressed: Santé biomedical segmentation under way, Logistique provider account separation completed; framework policy adapted by all four subsidiaries.
- 24 MONTHS Logistique IT/OT segmentation operational, Territoires logging centralised to the SOC. This is the milestone that makes an industrial ISO scope honestly declarable.
- THEREAFTER The Statement of Applicability, control by control – which has meaning only *after* the risk analysis. Today the Annex A block is a label on a screen, nothing more.

III.6

Decision requested

The Executive Committee is invited to approve the adoption of ISO/IEC 27001:2022 as the security framework of the MERIDIAN group, across the four subsidiaries, and the launch of the initial assessment already created in the governance tool, mandating the Group CISO to settle the deployment scope subsidiary by subsidiary.

Decision expected at Thursday's session. First step on the morning after a favourable opinion: opening of the initial assessment and notification to the four subsidiary CISOs of the evidence-collection schedule – with no new budget.

Statements this note deliberately does not make

- **That the choice is proven right.** The note makes the deliberation transparent and contestable; §II.5 shows precisely where a different doctrine would reverse it.
- **That the framework is adopted.** It is *recommended*. The decision belongs to the Committee, and this note is written so that “no” is a possible answer.
- **That the group is ready to be certified.** Without a Logistique network diagram and IT/OT segmentation, no scope including the industrial perimeter could be honestly declared today. The note says so before an auditor discovers it.
- **That we know what certification will cost.** We know what it will be *priced against*, which is a different and more honest claim – the drivers, the trigger and the missing input are named in §III.2 rather than replaced by an estimate.